

SIMATS ENGINEERING

ASSESSMENT TOOL 1

COURSE CODE: CSA51 COURSE NAME: Cryptography and Network Security

COURSE OUTCOME COVERED

CO5: *Develop the network security strategies based on the study of viruses, worms, firewall architectures, and IDS/IPS functionalities.CO (BL5, BL6)*

Assessment Tool Weightage: 40%

QUESTIONS: 5 TOTAL MARKS: 50 Annexure A

CONSTRAINT-BASED PROBLEM SOLVING

Code of Conduct:

I Daniel Jesuraji J (192565085) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Annexure A

CONSTRAINT-BASED PROBLEM SOLVING

1. A financial institution must secure all web transactions using TLS, but legacy systems only support older SSL versions. Design a solution to ensure secure communication.

Constraints:

- A. Backward compatibility must be maintained for 20% legacy clients

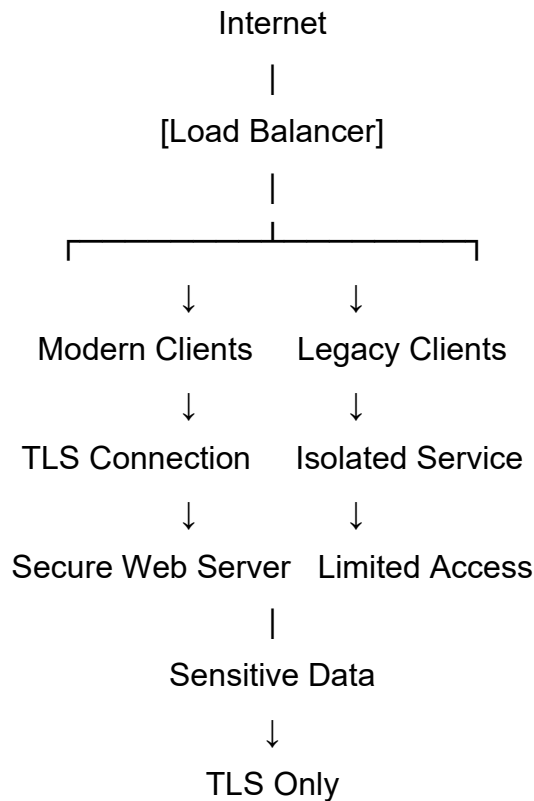
- B. Sensitive data must not be transmitted using SSL
- C. System downtime must be minimal during migration
- D. Cost of implementation should be optimized

A financial institution must secure all web transactions using **TLS**, while 20% of its legacy clients support only older **SSL** versions. The solution should maintain backward compatibility for the required legacy clients without allowing sensitive data to be transmitted using SSL. The migration should also minimize downtime and optimize implementation cost.

1. Proposed Solution

The institution should adopt a **phased migration from SSL to modern TLS**, while isolating legacy clients from sensitive transactions.

The proposed architecture is:



Modern clients should connect directly using **TLS**. Legacy clients can be supported through a separate, isolated service for non-sensitive functions. **Sensitive information must never be transmitted through the legacy SSL connection.**

2. Backward Compatibility

The system must support the **20% legacy clients** without compromising the security of sensitive transactions.

The following approach can be used:

- Identify and classify all legacy clients.
- Provide a separate legacy-access service.
- Restrict legacy clients to non-sensitive operations.
- Prevent access to payment, authentication, and other sensitive transactions through SSL.
- Encourage users and organizations using legacy systems to upgrade their clients.

This maintains necessary compatibility while protecting sensitive information.

3. Protection of Sensitive Data

Sensitive data should be transmitted **only through TLS-protected connections**.

Sensitive Transaction



TLS Connection



Secure Web Server



Allowed

Sensitive Transaction



SSL Connection



Blocked

This ensures that outdated SSL protocols are not used for financial or confidential transactions.

4. Minimizing System Downtime

Migration should be performed gradually rather than replacing the complete infrastructure at once.

Migration steps:

1. Identify SSL-dependent clients.

2. Deploy TLS support alongside the existing system.
3. Test TLS connections with modern clients.
4. Move users to TLS gradually.
5. Isolate remaining legacy clients.
6. Monitor the migration continuously.
7. Remove unnecessary SSL support after legacy usage is reduced.

Using parallel deployment and gradual migration helps keep downtime minimal.

5. Cost Optimization

Implementation costs can be controlled by:

- Reusing existing web servers and network infrastructure where possible.
- Upgrading software before replacing hardware.
- Using centralized load balancers or reverse proxies.
- Migrating clients in phases instead of upgrading all systems simultaneously.
- Prioritizing sensitive services for TLS migration first.
- Monitoring legacy-client usage to avoid unnecessary infrastructure.

6. Constraint Analysis

Constraint	Proposed Solution
20% legacy clients	Maintain isolated compatibility access for legacy clients
Sensitive data must not use SSL	Allow sensitive transactions only through TLS
Minimal downtime	Use phased and parallel migration
Optimized cost	Reuse existing infrastructure and upgrade gradually

Conclusion:

The financial institution should implement a **phased TLS migration strategy**. Modern clients should use TLS for all web transactions, while the 20% legacy clients should be isolated and restricted to non-sensitive services. Sensitive data must never be transmitted through SSL. A gradual migration using existing infrastructure will minimize downtime and control implementation costs. This approach provides a practical balance between **security, backward compatibility, availability, and cost**.

2. An e-commerce platform is considering implementing the SET protocol for payment security but currently uses TLS-based encryption. Analyze and propose a decision.

Constraints:

- A. Must support high transaction throughput (10,000 transactions/minute)
- B. Compatibility with modern browsers is required
- C. Implementation complexity should be minimized
- D. Regulatory compliance (PCI-DSS) must be ensured

An e-commerce platform is considering implementing the **Secure Electronic Transaction (SET)** protocol for payment security while currently using **TLS-based encryption**. The decision should consider transaction throughput, browser compatibility, implementation complexity, and PCI-DSS compliance.

1. Comparison of SET and TLS

Feature	SET	TLS
Primary Purpose	Secure electronic payment transactions	Secure communication over a network
Payment Protection	Specifically designed for card payments	Protects the communication channel
Browser Compatibility	Limited in modern environments	Widely supported
Implementation Complexity	High	Relatively low
Performance	Higher processing overhead	Generally efficient
Scalability	More complex to deploy	Highly scalable
Enterprise Deployment	Complex	Easier to integrate

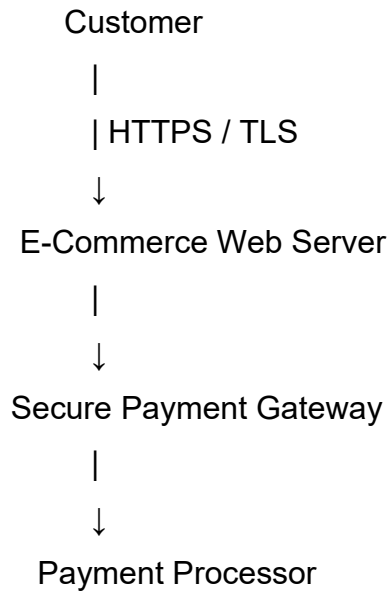
2. Proposed Decision

The e-commerce platform should **continue using TLS as the primary security protocol** rather than introducing SET as the main payment-security mechanism.

TLS is more suitable because the platform needs to support **modern browsers** and process a very high number of transactions. Introducing SET would increase

implementation complexity and may create compatibility challenges.

The proposed architecture is:



TLS protects the communication between the customer's browser and the e-commerce platform, while a secure payment gateway can be used for payment processing.

3. High Transaction Throughput

The platform must support **10,000 transactions per minute**.

Therefore, the system should:

- Use TLS with efficient cryptographic configurations.
- Deploy load balancing for web traffic.
- Use scalable payment-gateway infrastructure.
- Monitor server and network performance.
- Use session management and connection optimization where appropriate.

A simpler TLS-based architecture is easier to scale than introducing an additional complex payment protocol.

4. Modern Browser Compatibility

Modern browsers widely support **TLS-based HTTPS**, making TLS the practical choice for the platform.

SET would introduce additional compatibility and deployment considerations. Since modern browser compatibility is explicitly required, the platform should avoid making SET a mandatory client-side payment protocol.

5. Implementation Complexity

SET requires additional mechanisms for payment-specific security and certificate management. This can increase development, deployment, maintenance, and operational complexity.

TLS is already widely integrated into modern web infrastructure and can therefore be implemented with comparatively lower complexity.

6. PCI-DSS Compliance

The platform must ensure **PCI-DSS compliance** regardless of whether SET or TLS is used.

The organization should:

1. Protect payment-related data during transmission.
2. Use strong cryptographic protection.
3. Restrict access to payment information.
4. Maintain secure configurations.
5. Regularly monitor and test security controls.
6. Follow applicable PCI-DSS requirements.

Using TLS does not by itself guarantee PCI-DSS compliance; the complete payment environment must satisfy the required security controls.

7. Constraint Analysis

Constraint	Proposed Solution
10,000 transactions/minute	Use scalable TLS infrastructure, load balancing, and optimized payment processing
Modern browser compatibility	Use TLS/HTTPS as the primary web-security mechanism
Minimize implementation complexity	Continue with existing TLS infrastructure instead of introducing SET
PCI-DSS compliance	Apply required security controls throughout the payment environment

Conclusion

The e-commerce platform should **continue using TLS rather than adopting SET as its primary payment-security protocol**. TLS provides strong protection for web communication, broad modern-browser compatibility, and easier integration with scalable web infrastructure. SET can provide specialized payment security, but its additional complexity and compatibility considerations make it less suitable for this

scenario. The organization should combine TLS with a secure payment gateway and appropriate **PCI-DSS security controls** to achieve a secure and scalable payment environment.

3. A corporate network is experiencing repeated malware infections that spread rapidly without user interaction. Propose a containment and prevention strategy. **Constraints:**

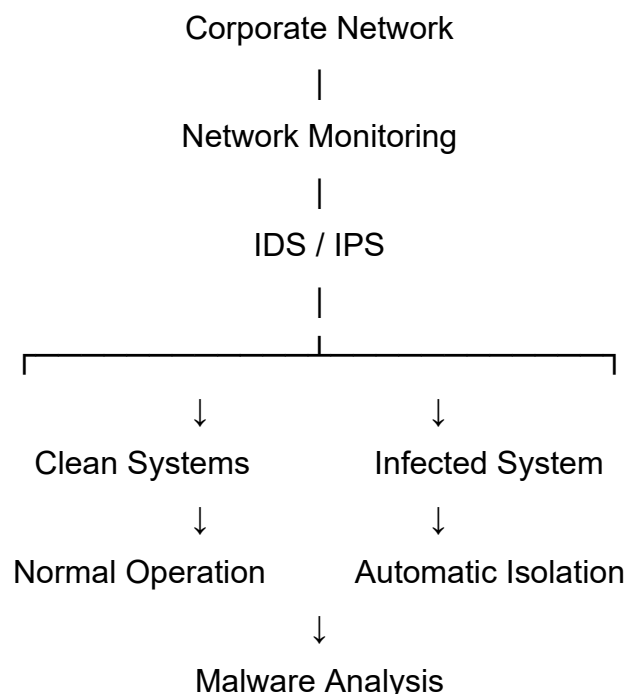
- A. The network consists of 500+ interconnected systems
- B. Downtime per system should not exceed 10 minutes
- C. Detection must occur within 2 minutes of infection
- D. Solution must differentiate between virus, worm, and Trojan behavior

A corporate network with more than **500 interconnected systems** is experiencing repeated malware infections that spread rapidly without user interaction. The organization needs a strategy that can detect infections within **2 minutes**, limit downtime to **10 minutes per system**, and differentiate between **virus, worm, and Trojan** behavior.

1. Proposed Solution

The organization should implement a **layered malware detection and containment system** combining endpoint protection, network monitoring, IDS/IPS, network segmentation, and automated isolation.

The proposed architecture is:



↓
Removal / Recovery

2. Malware Detection

The system should continuously monitor endpoint and network activity.

Malware Type	Typical Behavior	Detection Approach
Virus	Attaches itself to files and spreads when infected files are executed	File and endpoint monitoring
Worm	Spreads automatically across network systems	Network traffic and IDS/IPS monitoring
Trojan	Appears legitimate but performs malicious activities	Application and behavioral monitoring

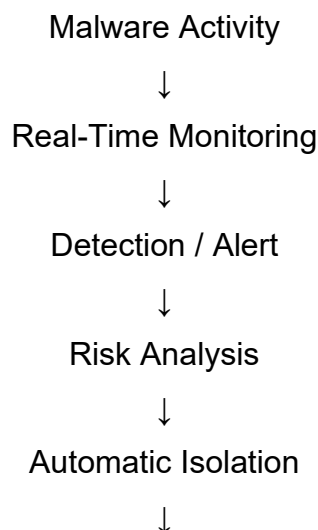
A combination of **signature-based and behavior-based detection** should be used to identify both known and suspicious malware activity.

3. Detection Within 2 Minutes

To satisfy the 2-minute detection requirement:

1. Deploy endpoint protection on all systems.
2. Continuously monitor system and network activity.
3. Use centralized security monitoring.
4. Configure real-time IDS/IPS alerts.
5. Automatically correlate suspicious events.
6. Trigger an isolation response when high-risk behavior is detected.

id="k7p4mz"



Within 2 Minutes

4. Containment and Prevention

Once an infected system is detected, it should be **automatically isolated** from the network.

The containment process should include:

- Block suspicious network connections.
- Isolate the infected endpoint.
- Prevent further lateral movement.
- Scan the affected system.
- Remove the malware.
- Apply security updates and patches.
- Restore the system to a trusted state.
- Reconnect the system only after verification.

Network segmentation should also be implemented so that an infection in one section of the network cannot easily spread to all 500+ systems.

5. Minimizing Downtime

The downtime requirement is **not more than 10 minutes per system**. Therefore, containment should be automated as much as possible.

The organization should use:

- Automated endpoint isolation.
- Centralized monitoring.
- Automated malware scanning.
- Predefined incident-response procedures.
- Regular backups.
- Rapid system recovery mechanisms.

This allows infected systems to be isolated quickly while the remaining systems continue operating.

6. Differentiating Virus, Worm, and Trojan

The detection system should use behavior-based indicators:

Virus:

- Detect unusual file modifications.
- Monitor suspicious file execution.
- Identify unauthorized changes to executable files.

Worm:

- Monitor rapid network scanning.
- Detect unusual connection attempts between systems.
- Identify abnormal lateral movement.

Trojan:

- Monitor suspicious application behavior.
- Detect unauthorized communication with external systems.
- Identify programs performing activities outside their expected behavior.

7. Constraint Analysis

Constraint	Proposed Solution
500+ interconnected systems	Use centralized monitoring, endpoint protection, and network segmentation
Downtime $\leq$ 10 minutes/system	Use automated isolation, scanning, and recovery
Detection $\leq$ 2 minutes	Use real-time endpoint and IDS/IPS monitoring
Differentiate malware types	Use behavior-based analysis along with signature detection

Conclusion

The organization should implement a **layered malware defense strategy** using endpoint protection, IDS/IPS, network segmentation, centralized monitoring, and automated isolation. Real-time monitoring can help detect infections within the required **2-minute period**, while automated containment can reduce system downtime. Differentiating virus, worm, and Trojan behavior allows the security team to apply appropriate containment and prevention measures.

4. An organization needs to deploy a firewall architecture to protect its internal network from external threats and insider attacks. Design the solution.

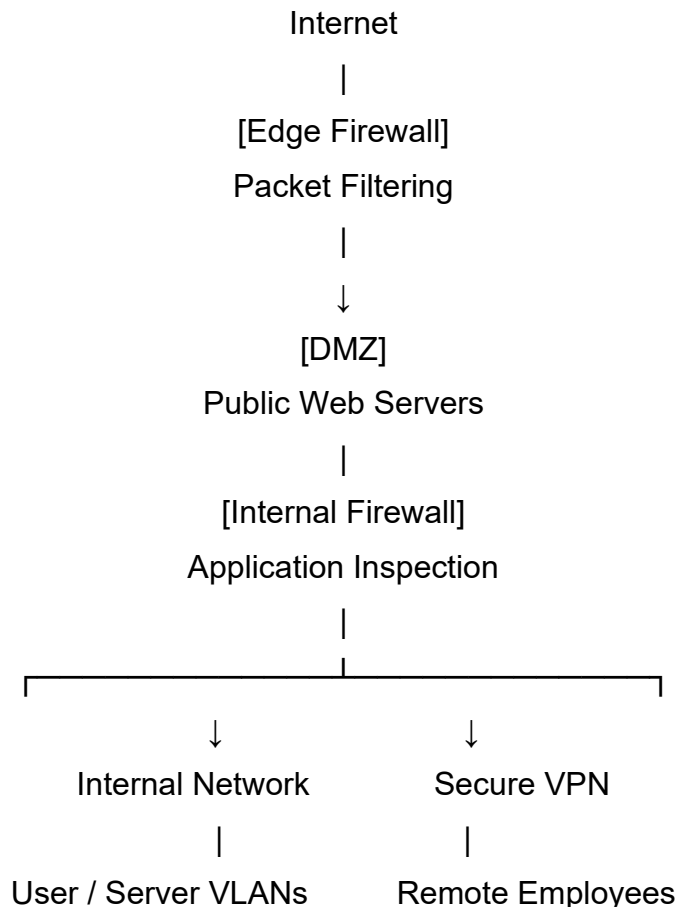
Constraints:

- A. Must support both packet filtering and application-level inspection
- B. Latency introduced should not exceed 5 ms per request
- C. Should handle at least 1 Gbps traffic
- D. Must allow secure remote access for employees

An organization needs a firewall architecture that protects its internal network from **external threats and insider attacks**. The firewall must support both **packet filtering and application-level inspection**, introduce no more than **5 ms latency per request**, handle at least **1 Gbps traffic**, and provide secure remote access for employees.

1. Proposed Firewall Architecture

A **multi-layer firewall architecture** should be implemented using packet filtering, application-level inspection, network segmentation, and secure remote access.



The architecture provides multiple layers of protection instead of depending on a single firewall.

2. Packet Filtering

The edge firewall should perform **packet filtering** based on:

- Source IP address
- Destination IP address
- Port number
- Protocol
- Connection state

Only required network traffic should be permitted.

Internet Traffic



Packet Filtering



Allowed → Forward

Blocked → Drop

This provides fast protection against unauthorized network connections.

3. Application-Level Inspection

An internal or next-generation firewall should perform **application-level inspection**.

It can inspect:

- HTTP/HTTPS traffic
- Application protocols
- Suspicious requests
- Unauthorized application activity
- Malicious payload patterns

Application inspection provides deeper security than simple packet filtering because it examines traffic at the application level.

4. Protection Against External and Insider Threats

External threats:

- Block unauthorized inbound connections.
- Allow only required services.
- Inspect application traffic.
- Monitor suspicious network activity.

Insider threats:

- Segment the internal network using VLANs.
- Apply access-control policies between network segments.
- Monitor unusual internal traffic.
- Restrict access based on user and system requirements.
- Log security events for investigation.

Therefore, even if an attacker gains access to one internal segment, network segmentation can limit further movement.

5. Performance Requirement

The firewall must handle at least **1 Gbps traffic** while keeping latency below **5 ms per request**.

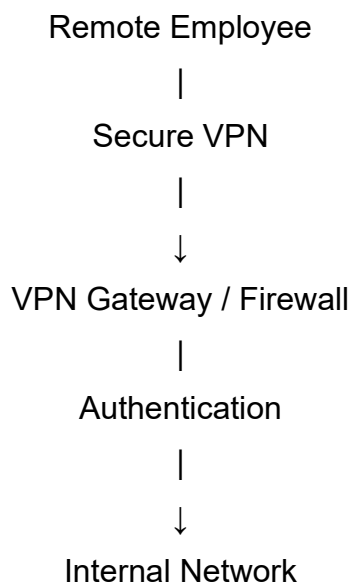
To satisfy this requirement:

1. Use high-performance firewall appliances.
2. Enable hardware acceleration where available.
3. Apply efficient packet-filtering rules.
4. Avoid unnecessary deep inspection for trusted low-risk traffic.
5. Monitor throughput and latency continuously.
6. Use load balancing or redundant firewalls if required.

A layered design should ensure that security inspection does not create an excessive performance bottleneck.

6. Secure Remote Access

Employees working remotely should access the corporate network through a **VPN**.



The VPN should use strong authentication and encrypted communication. Access should be restricted according to the employee's role and required resources.

7. Constraint Analysis

Constraint

**Packet filtering +
application inspection**

Latency $\leq$ 5 ms/request

Proposed Solution

Edge firewall for packet filtering and internal/next-generation firewall for application inspection

High-performance firewall, optimized rules, and hardware acceleration

Constraint	Proposed Solution
Traffic ≥ 1 Gbps	High-throughput firewall infrastructure with performance monitoring
Secure remote access	VPN gateway with strong authentication and encrypted communication

Conclusion

The organization should deploy a **multi-layer firewall architecture** consisting of an edge packet-filtering firewall, DMZ, internal application-inspection firewall, network segmentation, and secure VPN access. This design protects against both external and insider threats while supporting the required **1 Gbps throughput, low latency, and secure remote access**.

5. A large enterprise network generates excessive false positives in its IDS, leading to alert fatigue. Propose an optimized IDS/IPS solution.

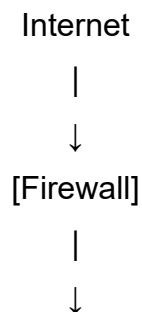
Constraints:

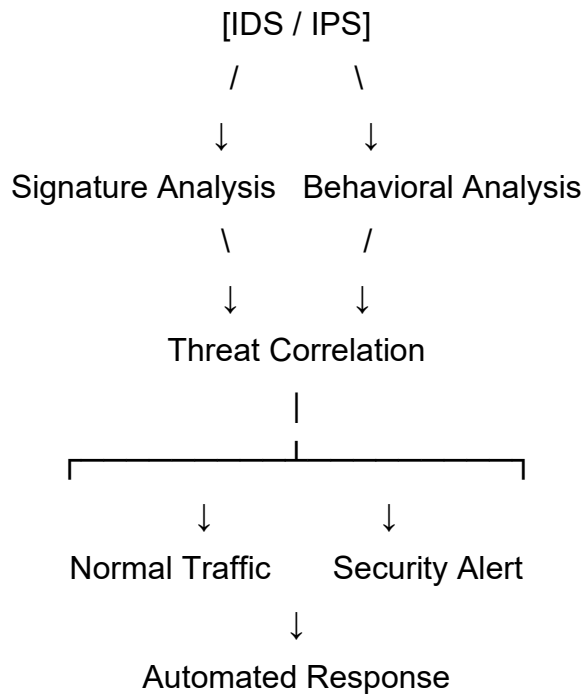
- A. Detection accuracy must be at least 95%
- B. False positive rate should be reduced below 5%
- C. System must process real-time traffic of 2 Gbps
- D. Solution should integrate with existing firewall infrastructure

A large enterprise network is experiencing excessive false positives in its Intrusion Detection System (IDS), resulting in **alert fatigue**. The organization requires an optimized IDS/IPS solution with at least **95% detection accuracy**, a **false positive rate below 5%**, real-time processing of **2 Gbps traffic**, and integration with the existing firewall infrastructure.

1. Proposed IDS/IPS Architecture

The organization should deploy a **hybrid IDS/IPS solution** that combines signature-based detection, behavioral analysis, centralized monitoring, and firewall integration.





The IDS/IPS continuously monitors network traffic and identifies suspicious activities before they can cause significant damage.

2. Improving Detection Accuracy

To achieve the required **95% detection accuracy**, the organization should combine multiple detection techniques.

Signature-Based Detection:

- Identifies known attacks using predefined signatures.
- Provides fast detection of known threats.
- Requires regular signature updates.

Behavior-Based Detection:

- Identifies unusual network behavior.
- Can detect previously unknown or modified attacks.
- Uses baseline traffic patterns to identify anomalies.

Combining both techniques provides broader coverage than using either technique alone.

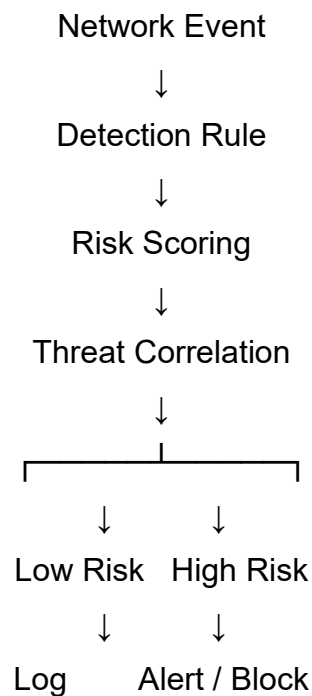
3. Reducing False Positives Below 5%

False positives occur when legitimate network activity is incorrectly classified as an attack.

The following measures should be implemented:

1. Establish a baseline of normal network traffic.

2. Tune IDS/IPS rules according to the organization's environment.
3. Remove outdated or unnecessary signatures.
4. Use multiple indicators before generating high-priority alerts.
5. Maintain trusted-source and approved-activity lists.
6. Continuously review false-positive events.
7. Use threat intelligence to improve detection decisions.
8. Automatically prioritize alerts according to their risk level.



This reduces unnecessary alerts and allows security teams to focus on genuine threats.

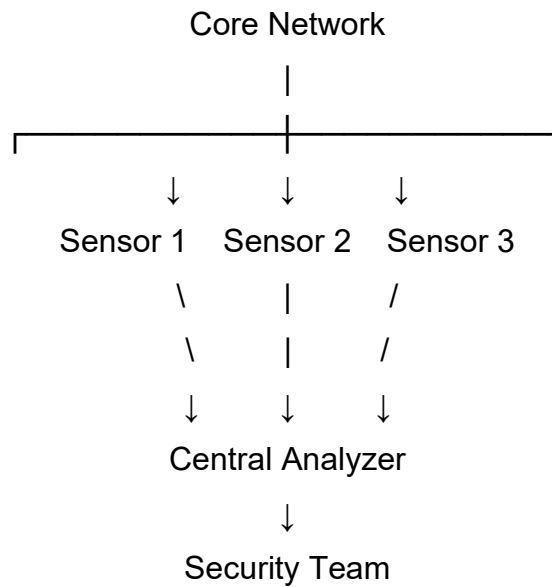
4. Real-Time Processing of 2 Gbps Traffic

The IDS/IPS must process **2 Gbps of real-time traffic** without becoming a network bottleneck.

The organization should:

- Use high-performance IDS/IPS hardware.
- Use hardware acceleration where available.
- Optimize detection rules.
- Remove redundant inspection rules.
- Distribute traffic across multiple sensors if necessary.
- Continuously monitor throughput and processing latency.

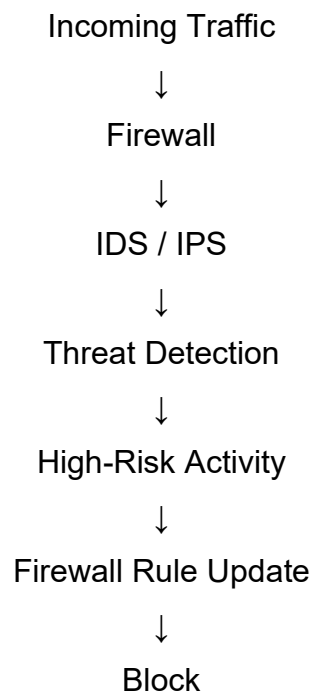
A distributed IDS/IPS architecture can be used for very large networks:



5. Integration with Existing Firewall

The IDS/IPS should integrate directly with the organization's existing firewall.

The firewall can provide network access control, while the IDS/IPS provides detailed threat detection and response.



For example, when the IDS/IPS detects a confirmed malicious source, it can communicate with the firewall to block the source according to the organization's security policy.

6. Constraint Analysis

Constraint	Proposed Solution
Detection accuracy $\geq$ 95%	Combine signature-based and behavior-based detection
False positive rate < 5%	Rule tuning, traffic baselining, risk scoring, and alert correlation
Real-time traffic of 2 Gbps	High-performance sensors, optimized rules, and distributed processing
Existing firewall integration	Connect IDS/IPS alerts with firewall access-control mechanisms

Conclusion

The enterprise should implement a **hybrid, high-performance IDS/IPS architecture** combining signature-based detection, behavioral analysis, threat correlation, and firewall integration. Proper rule tuning and traffic baselining can reduce false positives to **below 5%**, while high-performance or distributed sensors can support **2 Gbps real-time traffic**. This approach can improve detection accuracy toward the required **95% or higher** while reducing alert fatigue and strengthening the organization's overall network security.